Introduction to Cryptography

Lecture 2: Computer Security Concepts and CIA Triad

Dr. Siddhant Thapliyal

Department of Computer Science and Engineering
Graphic Era (Deemed to be University), Dehradun

What is Computer Security?

Computer Security

Computer security protects information systems from unauthorized access, misuse, modification, disruption, and destruction.

Computer security focuses on protecting:

- Data and information
- Software and programs
- Computer hardware
- Communication networks
- Services and users

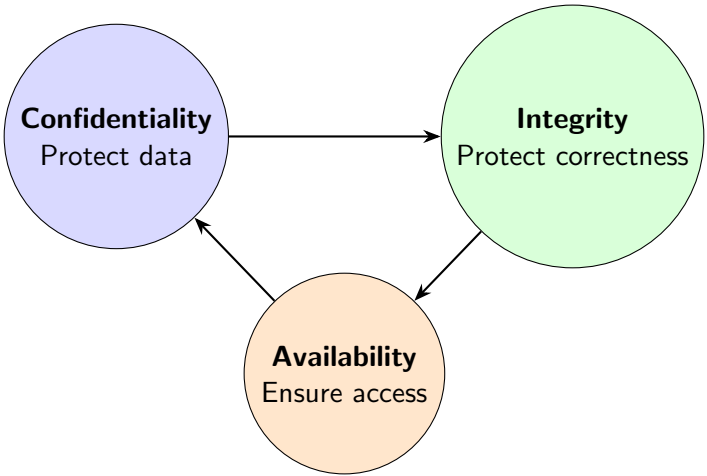
Why is Security Important?

- Organizations store large amounts of sensitive information digitally.
- Online services must remain reliable and trustworthy.
- Cyberattacks may cause data leakage and financial loss.
- Unauthorized changes may make information unreliable.
- Service disruption may affect business and human life.
- Cryptography supports several important security goals.

Examples

Online banking, healthcare systems, university portals, e-commerce, IoT devices, cloud services, and military communication.

Security Requirements Triad



CIA Triad represents the three fundamental objectives of information and computer security.

Confidentiality

Definition

Confidentiality ensures that private or sensitive information is not disclosed or made available to unauthorized individuals or systems.

- Only authorized users should access sensitive information.
- It protects personal and organizational information.
- It prevents unauthorized information disclosure.
- It applies to stored data as well as transmitted data.

Example

Student grade records should be visible only to authorized students, parents, teachers, and administrative staff.

Methods for Providing Confidentiality

- Encryption
- Authentication
- Password protection
- Access control
- Data classification
- Secure communication protocols
- Physical security

Cryptographic Support

Encryption converts readable information into an unreadable form so that unauthorized entities cannot understand it.

Privacy and Confidentiality

Confidentiality

Protects sensitive information from unauthorized access or disclosure.

Privacy

Allows individuals to control or influence how their personal information is collected, stored, processed, shared, and disclosed.

Example

A student may permit the university to store academic records but may not permit the university to publicly disclose the grades.

Loss of Confidentiality

Meaning

A loss of confidentiality occurs when information is disclosed to an unauthorized person, organization, or computer system.

- Leakage of usernames and passwords
- Unauthorized access to medical records
- Public disclosure of student grades
- Exposure of credit card information
- Leakage of confidential business documents
- Data breach in cloud storage

Integrity

Definition

Integrity ensures that information, programs, and systems are modified only in a specified and authorized manner.

- Information should remain accurate.
- Information should remain complete.
- Information should remain consistent.
- Unauthorized modification must be prevented.
- Unauthorized destruction must be detected.

Types of Integrity

Data Integrity

Ensures that data and programs are changed only in an authorized and specified manner.

System Integrity

Ensures that a system performs its intended functions correctly, without unauthorized manipulation.

Example

A hospital database must contain correct and current information about a patient's allergies.

Methods for Providing Integrity

- Cryptographic hash functions
- Message Authentication Codes
- Digital signatures
- Checksums
- File permissions
- Version control
- Audit logs
- Database constraints

Cryptographic Support

Hash functions and digital signatures can detect unauthorized changes in data.

Loss of Integrity

Meaning

A loss of integrity occurs when information is modified, deleted, or destroyed without authorization.

- Altering marks in a university database
- Changing an account balance in banking software
- Modifying patient allergy information
- Defacing a website
- Changing source code without authorization
- Manipulating transaction records

Availability

Definition

Availability ensures timely and reliable access to information, systems, and services for authorized users.

- Systems should remain operational when required.
- Information should be accessible without unreasonable delay.
- Services should not be denied to legitimate users.
- Critical systems should tolerate failures and attacks.

Example

A university authentication server should remain available when students access the LMS, ERP, or examination portal.

Methods for Providing Availability

- Regular data backups
- Redundant servers
- Fault-tolerant systems
- Disaster recovery plans
- Load balancing
- Network monitoring
- Uninterruptible power supply
- DoS and DDoS protection

Loss of Availability

Meaning

A loss of availability occurs when authorized users cannot access information, systems, or services.

- Server failure during examination form submission
- DDoS attack on an online banking portal
- Power failure in a data centre
- Ransomware locking hospital systems
- Network equipment failure
- Accidental deletion of a critical service

CIA Triad and Security Controls

Goal	Purpose	Common Controls
Confidentiality	Prevent unauthorized disclosure	Encryption, authentication, access control
Integrity	Prevent unauthorized modification	Hashing, digital signatures, checksums
Availability	Ensure reliable access	Backups, redundancy, DoS protection

FIPS 199 Security Objectives

According to FIPS Publication 199:

Confidentiality

Preserving authorized restrictions on information access and disclosure, including the protection of privacy and proprietary information.

Integrity

Guarding against improper information modification or destruction and ensuring authenticity and nonrepudiation.

Availability

Ensuring timely and reliable access to and use of information.

Additional Security Goals

The CIA triad does not represent every security requirement. Two additional goals are frequently considered:

Authenticity

The property of being genuine, verifiable, and trusted.

Accountability

The requirement that actions performed by an entity can be traced uniquely to that entity.

Authenticity

- Verifies that users are who they claim to be.
- Confirms that a message came from a trusted source.
- Verifies the identity of devices and applications.
- Prevents impersonation and spoofing attacks.
- Supports trusted communication.

Example

Before accessing an online examination portal, a student may prove identity using a username, password, and OTP.

Accountability

- Every important action should be linked to a user or process.
- System logs record activities performed by users.
- Accountability discourages malicious actions.
- It supports intrusion detection and forensic investigation.
- It helps resolve transaction and legal disputes.
- It supports nonrepudiation.

Example

If marks are changed in the university ERP, the system should record who changed them, when they were changed, and from which device.

Security Impact Levels

Level	**Possible Impact**
Low	Limited adverse effect, minor financial loss, inconvenience, or reduced operational efficiency.
Moderate	Serious adverse effect, significant operational degradation, financial loss, or harm to individuals.
High	Severe or catastrophic effect, major financial loss, mission failure, or life-threatening harm.

Low Impact

A security breach has a **low impact** when it may:

- Cause limited disruption
- Slightly reduce organizational efficiency
- Cause minor damage to assets
- Produce minor financial loss
- Cause limited inconvenience to individuals

Example

Temporary unavailability of an online telephone directory may inconvenience users, but alternative sources are available.

Moderate Impact

A security breach has a **moderate impact** when it may:

- Significantly reduce operational effectiveness
- Cause considerable damage to assets
- Produce significant financial loss
- Cause serious harm to individuals
- Damage organizational reputation

Example

The temporary failure of a university website may affect students, applicants, parents, and donors.

High Impact

A security breach has a **high impact** when it may:

- Cause complete mission failure
- Stop critical organizational functions
- Produce major financial loss
- Cause catastrophic damage to assets
- Result in serious injury or loss of life

Example

Incorrect patient allergy information may cause the administration of a dangerous medicine and result in serious injury or death.

Example: Confidentiality Levels

- **High:** Student grades, medical records, banking credentials
- **Moderate:** Student enrollment information and internal records
- **Low:** Public departmental and faculty directory information

Key Idea

The more sensitive the information, the higher the confidentiality requirement.

Example: Integrity Levels

- **High:** Patient allergy information in a hospital database
- **Moderate:** Posts on a discussion forum
- **Low:** Anonymous online poll results

Key Idea

In a critical system, incorrect information may be more dangerous than temporarily unavailable information.

Example: Availability Levels

- **High:** Authentication services for critical applications
- **Moderate:** Public university website
- **Low:** Online telephone directory lookup

Key Idea

Critical services require backup servers, redundancy, fault tolerance, and strong recovery mechanisms.

University Information System Example

Requirement	**Example**
Confidentiality	Only authorized users can view student grades.
Integrity	Marks cannot be modified without authorization.
Availability	Students can access the ERP during registration and examination periods.
Authenticity	The system verifies the identity of students and teachers.
Accountability	Every change in marks is recorded in an audit log.

Hospital Information System Example

- **Confidentiality:** Patient records should remain private.
- **Integrity:** Allergy and medication information must be correct.
- **Availability:** Doctors must access records during emergencies.
- **Authenticity:** Only verified doctors and staff should log in.
- **Accountability:** Every access and modification should be logged.

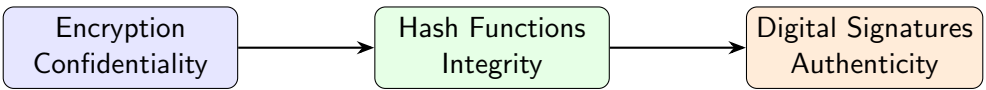
Critical Observation

A failure of confidentiality, integrity, or availability in healthcare may directly affect human life.

Threats to the CIA Triad

Security Goal	**Common Threats**
Confidentiality	Eavesdropping, data leakage, unauthorized access, phishing
Integrity	Malware, data manipulation, SQL injection, unauthorized modification
Availability	DoS, DDoS, ransomware, hardware failure, power failure

Role of Cryptography in Security



Cryptography provides mathematical techniques to:

- Protect information from unauthorized disclosure
- Detect unauthorized modification
- Verify identity and message origin
- Support nonrepudiation

Cryptography and Availability

Cryptography directly supports confidentiality, integrity, authenticity, and nonrepudiation.

However, cryptography alone cannot guarantee availability.

Availability Requires

- Redundant infrastructure
- Backup systems
- Network defence
- Fault tolerance
- Disaster recovery
- DoS and DDoS protection

Class Discussion

Identify the violated security objective in each situation:

1. Student examination marks are changed illegally.
2. A website becomes inaccessible due to a DDoS attack.
3. Student grades are leaked publicly.
4. An attacker logs in using another student's identity.
5. The system cannot determine who deleted an important file.

Discussion Answers

1. Illegal modification of marks: **Integrity**
2. Website inaccessible due to DDoS: **Availability**
3. Leakage of student grades: **Confidentiality**
4. Login using another identity: **Authenticity**
5. Inability to identify the responsible user: **Accountability**

Quick Quiz

1. What does CIA stand for?
2. Which security objective prevents unauthorized disclosure?
3. Which security objective prevents unauthorized modification?
4. Which objective ensures timely access to services?
5. Which cryptographic technique mainly supports confidentiality?
6. Which cryptographic technique detects data modification?
7. Give one example of a high availability requirement.

Summary

- The CIA triad defines the core objectives of computer security.
- Confidentiality prevents unauthorized disclosure.
- Integrity prevents unauthorized modification or destruction.
- Availability ensures reliable and timely access.
- Authenticity verifies users, devices, and message sources.
- Accountability makes actions traceable.
- Security impact may be classified as low, moderate, or high.
- Cryptography provides important tools for achieving security.

References

- William Stallings, *Cryptography and Network Security: Principles and Practice*.
- William Stallings and Lawrie Brown, *Computer Security: Principles and Practice*.
- NIST FIPS Publication 199, *Standards for Security Categorization of Federal Information and Information Systems*.
- RFC 2828, *Internet Security Glossary*.

Thank You

Questions and Discussion